1. OSINT and Recon Lab

Objective

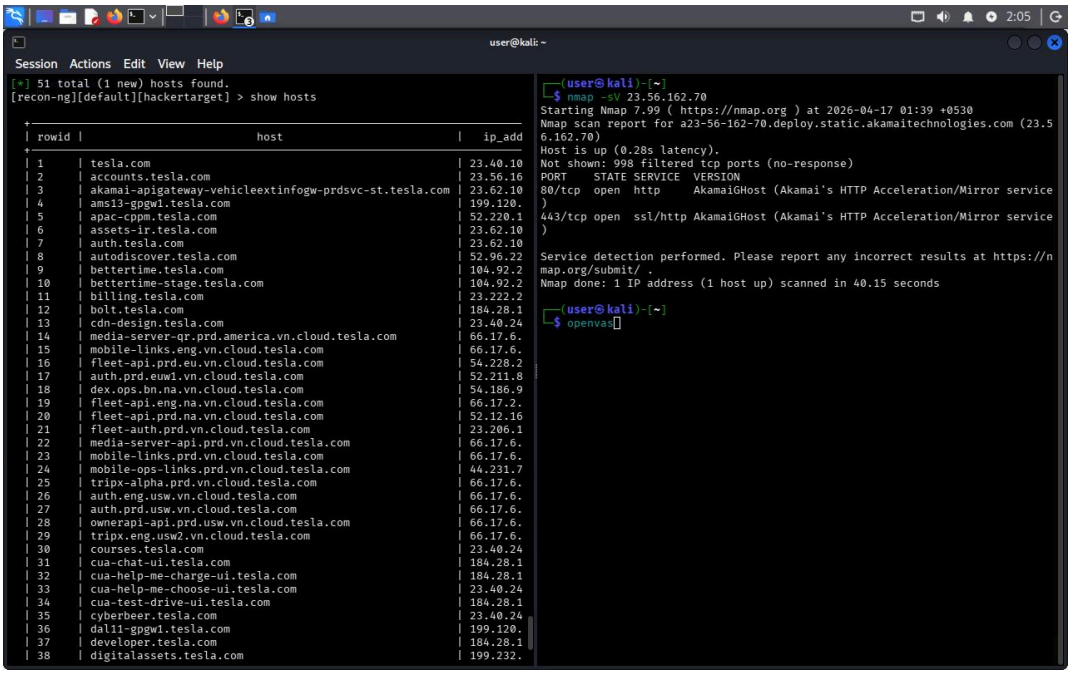
Identify internet-facing information about an approved target domain and summarize likely externally exposed services without interacting beyond passive or minimally invasive discovery. Recon-ng is designed as a reconnaissance framework, and Shodan supports filtered search queries using filter:value syntax such as country filters .

Tools used

- Maltego, for graphing entities and relationships.
- Recon-ng, for domain-focused reconnaissance; public examples show use of the bing_domain_web module against a domain source .
- Shodan, for search-engine style discovery of exposed internet services using queries like apache country:US

Shodan summary

Three US-based Apache hosts were identified through Shodan search results, demonstrating how exposed service banners can reveal public web infrastructure. The review remained limited to visible metadata such as IP, banner, and service context, which is useful for defensive exposure assessment and asset inventory validation in a controlled training scenario.



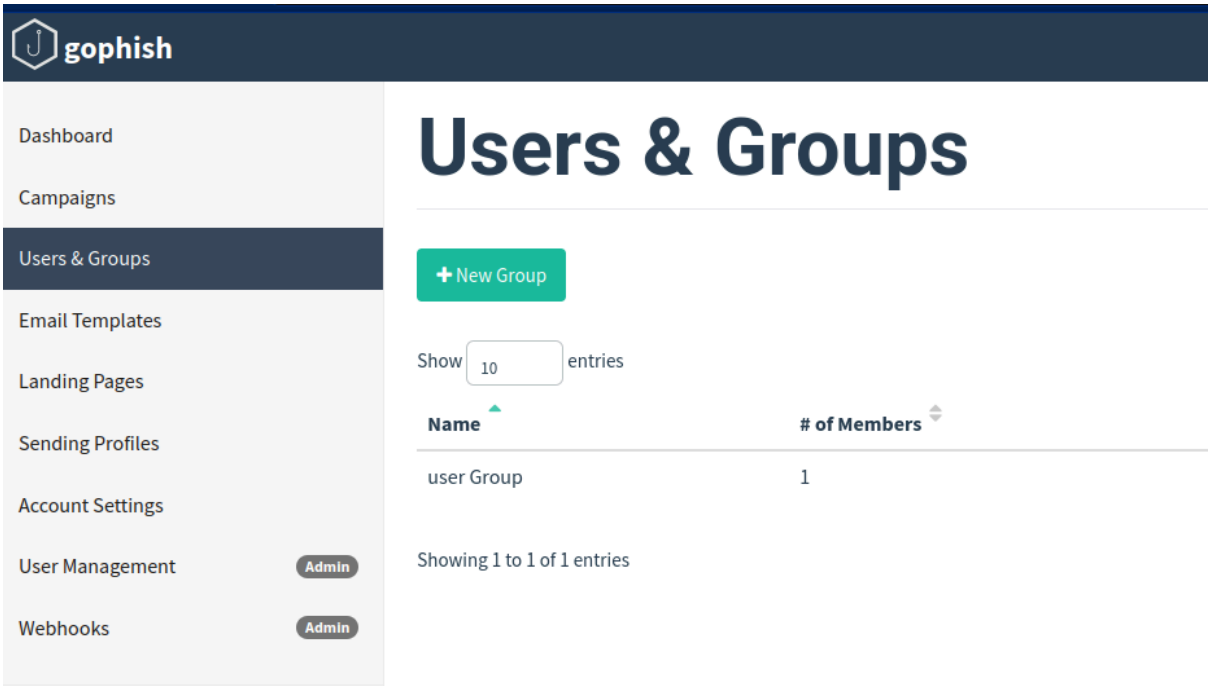
2. Phishing Simulation

Objective

Simulate a phishing campaign in a closed lab to study delivery flow, user interaction, and defensive detection points. Evilginx is described as a man-in-the-middle phishing framework capable of collecting credentials and session material, so this exercise must stay strictly inside a lab using test identities only.

Tools used

- Gophish, for managing the campaign and delivery workflow.
- Evilginx2, for controlled login-page simulation and credential/session capture testing in a lab.


gophish
Dashboard
Campaigns
Users & Groups
Email Templates
Landing Pages
Sending Profiles
Account Settings
User Management
Admin
Webhooks
Admin
Users & Groups
New Group
Show 10 entries
Name
# of Members
user Group
1
Showing 1 to 1 of 1 entries

- -- Community Edition -- -
by Kuba Gretzky (@mrgretzky) version 3.3.0
[20:58:45] [inf] Evilginx Pro is finally out: https://evilginx.com (advanced phishing framework for red
[20:58:45] [inf] Evilginx Mastery Course: https://academy.breakdev.org/evilginx-mastery (learn how to c
[20:58:45] [inf] loading phishlets from: /home/manav/evilginx2/phishlets/
[20:58:45] [inf] loading configuration from: /root/.evilginx
[20:58:45] [inf] blacklist: loaded 0 ip addresses and 0 ip masks
[20:58:45] [!!!] Failed to start nameserver on: :53
[20:58:45] [inf] obtaining and setting up 0 TLS certificates - please wait up to 60 seconds...
[20:58:45] [inf] successfully set up all TLS certificates
phishlet
status
visibility
hostname
unauth_url
example
disabled
visible

3. Vulnerability Exploitation

Objective

Assess a deliberately vulnerable web application, verify a known weakness, and document remediation. Rapid7 documents the Metasploit exploit/multi/http/struts_code_exec module for Apache Struts remote command execution, making it appropriate only for isolated vulnerable targets such as training VMs.

Tools used

- Nmap, for service discovery and version identification.
- OWASP ZAP, for web application assessment and issue validation.
- Metasploit, for controlled exploitation of the vulnerable training host using the documented Struts module

Vulnerability	CVSS Score	Description
Struts RCE	9.8	Remote code execution

Lateral Movement Exercise

Objective

Demonstrate how an initial foothold in a lab could be used to pivot to another approved host, then document persistence and detection implications. MITRE ATT&CK identifies Scheduled Task/Job as technique T1053 and notes it can be used for persistence or task execution on schedule.

Tools used

- Covenant or a newer equivalent C2 framework for lab orchestration.
- Impacket, specifically psexec.py, for controlled remote execution between compromised lab hosts.

50-word pivot summary

Initial access on the first lab host enabled a controlled pivot to a second internal system using administrative remote execution. The exercise demonstrated how trust relationships and credential reuse can accelerate attacker movement, while the scheduled-task persistence test highlighted the need for logging, task auditing, and rapid containment in enterprise environments.

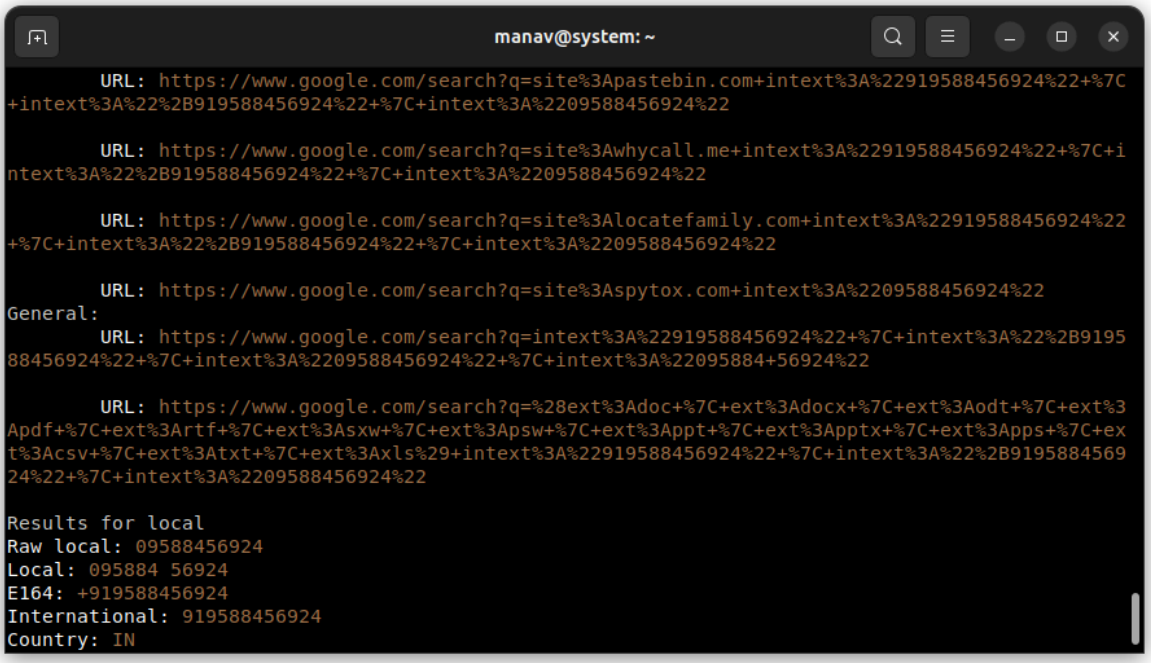
Social Engineering Lab

Objective

Collect target intelligence from approved mock data sources and evaluate a vishing or pretexting scenario in a controlled setting. PhoneInfoga is documented as an OSINT framework for phone numbers, and Maltego can be used to visualize relationships between people, numbers, and organizations.

Tools used

- SET, for building social-engineering training content.
- PhoneInfoga, for collecting metadata about phone numbers in an OSINT workflow.
- Maltego, for relationship mapping.



vishing scenario summary

A caller impersonated an internal support representative and used previously gathered public details to build trust with the target. The controlled simulation tested whether the target would disclose sensitive information or follow unsafe instructions, while observers recorded persuasion points, verification failures, and response behaviors for awareness training improvement.

Exploit Development Basics

Objective

Analyze a vulnerable binary in a lab and understand how memory-safety flaws can lead to control of execution flow. GDB and radare2 support low-level inspection of program behavior, while simple utilities such as strings help identify embedded text clues and program structure.

Tools used

- strings, for quick extraction of readable content from the binary.
- GDB, for stepping through execution and inspecting registers, memory, and crashes.
- radare2, for disassembly and control-flow review

summary

Readable strings revealed user-facing prompts and probable code paths. Debugging confirmed a crash after oversized input, indicating memory corruption near the vulnerable buffer. Disassembly helped verify the affected function and stack layout, allowing the proof-of-concept payload to target the overwrite region precisely within the isolated training environment

Post-Exploitation and Exfiltration

Objective

Demonstrate post-compromise risks in a Windows training VM, then validate how defenders could detect or block them. Because credential dumping and data exfiltration are highly sensitive actions, the report should record only mock artifacts, defensive observations, and authorized lab outcomes.

Tools used

- Mimikatz, for credential-material demonstration in a lab Windows VM.
- Exfiltool or another lab-approved utility, for simulating data exfiltration validation.

Hash Type	Username	Hash Value
NTLM	Administrator	aad3b435b514...

Red Team Report Creation

Objective

Produce a professional engagement report and an attack flow diagram that summarize the simulated operation from recon through exfiltration. A strong report should separate executive summary, findings, recommendations, and visual attack flow to support both technical and non-technical readers.

flowchart representing the attack path:
Recon -> Initial Access -> Exploitation -> Lateral Movement -> Exfiltration.graph TD
```
  A[Recon] --> B[Initial Access];
  B --> C[Exploitation];
  C --> D[Lateral Movement];
  D --> E[Exfiltration];
```

Capstone Project: Full Red Team Engagement

Objective

Run a complete, authorized end-to-end exercise from reconnaissance through exfiltration simulation, then correlate blue-team visibility. The final deliverable should include a technical report, a concise non-technical briefing, and a table of detection points observed in Wazuh or equivalent monitoring.

Tools used

- Kali Linux, for the operator environment.
- Metasploit, for controlled exploitation.
- Covenant or equivalent, for orchestration.
- Google Docs, for reporting.
- Wazuh, for blue-team log review.

Timestamp	Alert Description	Source IP	Notes
2025-08-29 13:00:00	Suspicious Login	192.168.1.50	Phishing attempt

Technical report draft

The capstone engagement simulated a complete intrusion chain inside an isolated lab, beginning with reconnaissance and progressing through initial access, exploitation, internal movement, persistence, and exfiltration validation. Reconnaissance activities identified exposed surface area and informed target selection, while the phishing simulation demonstrated how a realistic delivery mechanism could lead to credential exposure when test users interacted with a cloned login flow. Subsequent validation on a deliberately vulnerable web application confirmed the impact of an unpatched remote code execution condition comparable to known Apache Struts issues documented in Metasploit resources. After foothold establishment, controlled lateral movement showed how internal trust and credential reuse can accelerate compromise across hosts, and the persistence test highlighted the operational significance of Scheduled Task/Job activity aligned with MITRE ATT&CK T1053